



Hack The Box

CURSO:
SEGURIDAD DEL SOFTWARE

WRITE-UP NIVEL I

Kener Adiel Castillo

June 23, 2026

Índice

1	Resumen ejecutivo	2
1.1	Alcance	2
1.2	Hallazgos y recomendaciones	2
2	Información general	2
3	Reconocimiento	3
3.1	Conexión y recopilación inicial de información	3
3.2	Puertos y servicios identificados	5
4	Enumeración y análisis	5
4.1	Hallazgos	5
4.2	Posibles vectores de ataque	5
4.3	Caminos probados	5
5	Explotación	6
5.1	Vulnerabilidades identificadas	6
5.2	Pasos para explotación	8
6	Evidencia de resolución	11
7	Remediación	11
8	Lecciones aprendidas	12
9	Recursos consultados	12

1 Resumen ejecutivo

El objetivo de este trabajo fue la realización y documentación del proceso y análisis de un challenge (reto) de pentesting en la plataforma Hack the Box (HTB); específicamente, se trató del challenge llamado "Meow" de la parte introductoria. Todo el ataque se realizó en un ambiente controlado establecido por la plataforma.

1.1 Alcance

El alcance (scope) de este challenge fue un sistema objetivo configurado por HTB con los siguientes detalles:

IP/Dirección	Sistema operativo
10.129.135.107	Linux

Table 1: Detalles del sistema objetivo

1.2 Hallazgos y recomendaciones

En total se encontraron tres vulnerabilidades principales relacionadas con el uso de credenciales simples y establecidas por defecto, la falta de medidas de seguridad en el inicio de sesión y el uso de servicios inseguros como Telnet, el cual era vulnerable a ataques al estar corriendo en un puerto abierto. Se identificaron dos posibles patrones de ataque de severidad alta y media relacionados con las debilidades de un método de autenticación.

Las recomendaciones se resumen en:

- Optar por servicios o protocolos más seguros.
- Analizar y proteger puntos de entrada al sistema como puertos abiertos.
- Definir credenciales seguros y medidas para protegerlos.

2 Información general

El challenge resuelto para este write-up pertenece a la plataforma Hack the Box (HTB), de la parte introductoria. Más detalles en la siguiente tabla.

Nombre	URL	Dificultad	Categoría	Fecha resolución	Username
Meow	HTB	Very Easy	Linux	21/04/2026	Kencast

Table 2: Información del challenge resuelto

3 Reconocimiento

3.1 Conexión y recopilación inicial de información

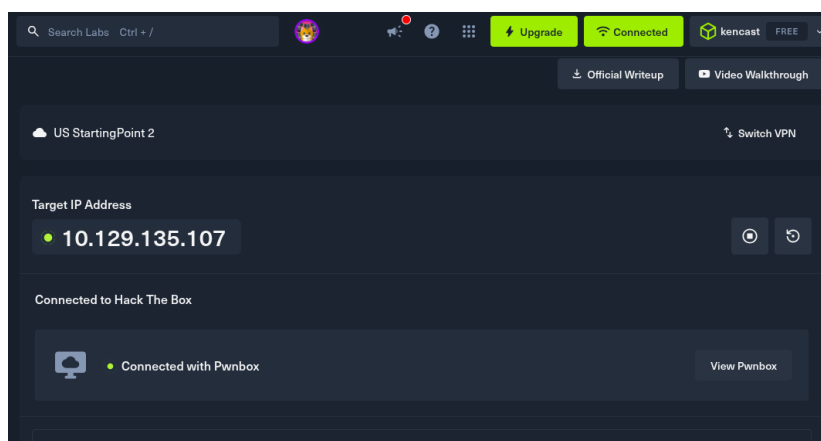


Figure 1: Encendiendo las máquinas

Para la conexión primero hay que encender la máquina objetivo en HTB, como se muestra en 1 esta se inicializa con una dirección IP 10.129.135.107. Seguidamente, hay que conectarse a la misma red de la máquina objetivo por medio de una máquina virtual. Hay dos formas de hacer esto, con OpenVPN de forma más local y con Pwnbox ofrecida de forma limitada por HTB, consultado en 9. En este caso, la conexión fue establecida con Pwnbox.

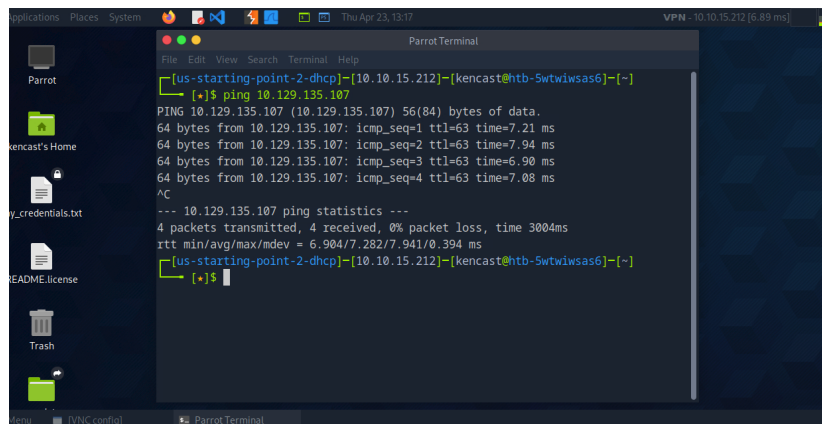


Figure 2: Probando conexión

Una vez estando en el entorno virtual, el cual tiene la IP 10.10.15.212 como se observa en 2, lo primero fue verificar la conexión con el objetivo. Para esto se puede usar el comando de Linux `ping {IP_OBJETIVO}` para verificar la llegada de paquetes desde IP_OBJETIVO 2.

La herramienta utilizada para la recopilación inicial de información fue Nmap(Network Mapper). Nmap es usado para descubrir hosts y servicios en una red de computadoras mediante el envío y análisis de paquetes. Entre muchas cosas permite detectar puertos abiertos y vulnerabilidades 9.

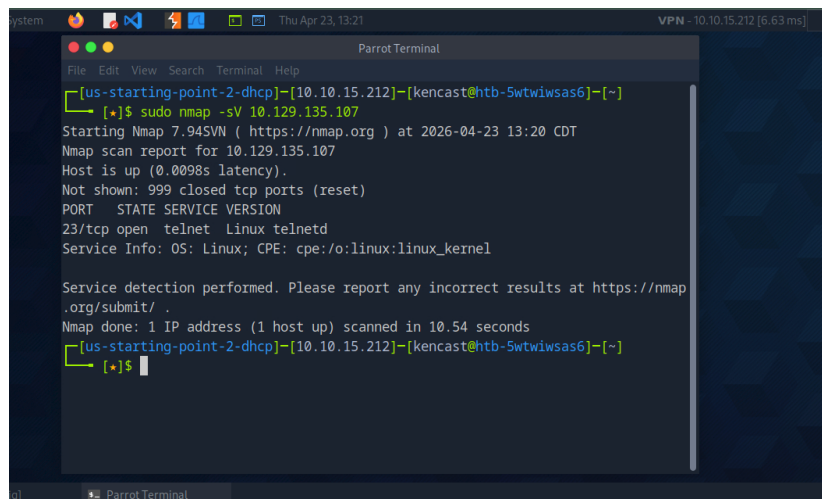


Figure 3: Escaneo con Nmap

Se usa el comando `sudo nmap -sV {IP_OBJETIVO}` con la bandera `-sV` para

detectar el software y versión que está corriendo en los puertos abiertos. En la figura 3 se observa el reporte generado por el comando en la IP 10.129.135.107, el cual solo cuenta con un puerto abierto.

3.2 Puertos y servicios identificados

Puerto	Servicio	Versión
23/tcp	telnet	Linux telnetd

Table 3: Puertos abiertos encontrados

En la tabla 3 y en la figura 3 se muestra solo un puerto abierto encontrado, lo que quiere decir que el servicio `telnet` está corriendo en el puerto `23/tcp`, lo cual es lo único encontrado.

4 Enumeración y análisis

4.1 Hallazgos

El único hallazgo fue que el servicio Telnet estaba corriendo en el puerto abierto `23/tcp`. Investigando un poco en internet 9, el puerto 23 es el puerto tcp usado por default por el protocolo Telnet para proveer acceso remoto por terminal a dispositivos y servidores en la red. Sin embargo, como Telnet transmite todos los datos sin encriptar (incluidos usuarios y contraseñas) es considerado inseguro y ha sido reemplazado por SSH en la actualidad. Por otra parte, Telnet permite a otros usuarios hacer login en otro sistema en la red para ejecutar comandos como si fuera localmente. La falta de encriptación y buenos mecanismos de autenticación hace que sea uno de los puertos más vulnerables, expuestos a ataques de fuerza bruta.

4.2 Posibles vectores de ataque

De esta forma, este puerto es una vulnerabilidad y una posible entrada al sistema target. Una posible forma de ataque sería entonces tratar de hacer login probando distintas credenciales hasta lograr entrar y tomar control del sistema.

4.3 Caminos probados

El camino en este challenge es bastante claro, ya que la investigación sobre Telnet y las preguntas que aparecen en el challenge sugieren encontrar el username que

logra hacer login en el sistema con una contraseña vacía, lo cual limita las posibilidades. La dificultad principal entonces fue probar diferentes nombres de usuario.

5 Explotación

5.1 Vulnerabilidades identificadas

ID	Nombre	Descripción
CWE-1392	Use of Default Credentials	El producto usa credenciales por defecto como contraseñas y nombre de usuario, los cuales no se cambiaron.
CWE-319	Cleartext transmission of sensitive information	El producto transmite información sensible sin encriptar por lo canales de comunicación.
CWE-307	Improper restriction of excessive authentication attempts	El producto no previene múltiples intentos fallidos de autenticación en un periodo corto de tiempo.

Table 4: Principales vulnerabilidades encontradas en la fuente CWE [9](#)

ID	Nombre	Severidad	Descripción
CAPEC-16	Dictionary-based password attack	Alta	Un atacante prueba todas las palabras de un diccionario como contraseñas para ganar acceso al sistema. Tipo de ataque fuerza bruta.
CAPEC-114	Authentication abuse	Media	Un atacante obtiene acceso no autorizado a un servicio por medio del conocimiento de debilidades de un mecanismo de autenticación.

Table 5: Principales patrones de ataque encontrados en la fuente CAPEC 9

En las tablas 4 y 5 se muestran las principales vulnerabilidades encontradas relacionadas con los riesgos más importantes del servicio Telnet y el uso de credenciales débiles. Específicamente, Telnet no encripta los datos en la comunicación (CWE-319), toda la información viaja en texto plano, por lo que las contraseñas e información sensible pueden ser interceptadas por terceros.

Por otra parte, este servicio no cuenta con buenas medidas de seguridad para el inicio de sesión (CWE-307), no hay un "cooldown" entre cada intento fallido y no hay un límite de oportunidades totales, lo que puede permitir un ataque de fuerza bruta por medio del uso de nombres de usuarios y contraseñas comunes o basadas en un diccionario (CAPEC-16). Telnet es considerado un servicio inseguro que se recomienda dejar de usar por lo descrito anteriormente, esto lo hace un objetivo buscado por atacantes para entrar a un sistema de forma no autorizada (CAPEC-114).

A pesar de tener acceso al servicio por medio del puerto abierto 23/tcp, para entrar al sistema se necesita hacer inicio de sesión con el nombre de usuario y contraseña correctos. Las vulnerabilidades anteriores permiten interceptar las credenciales o hacer un ataque de fuerza bruta. Sin embargo, la definición de credenciales muy seguras y rotativas puede complicar un ataque de este estilo. Lo que aumenta el riesgo y permite la entrada al sistema en este caso es el uso de credenciales por defecto (CWE-1392) o muy parecidas a estas. Como se ve en la siguiente sección 5.2, el inicio de sesión para el servicio Telnet en el sistema objetivo cuenta con una contraseña vacía y un nombre de usuario extremada-

mente común, el cual es posible descifrar por medio de algunos intentos usando un banco de palabras.

En este caso, al tratarse de vulnerabilidades un poco generales que pueden presentarse en diferentes dispositivos que no cuenten con las medidas de seguridad necesarias, no hay un CVE (Common Vulnerabilities and Exposures) específico. Solo se encuentran casos relacionados de estas en dispositivos como routers que traen contraseñas "hard-coded" o que en ocasiones permiten acceso sin autenticación [9](#).

Respecto a la relación con los contenidos del curso, estas vulnerabilidades y patrones de ataques corresponden principalmente al reino de "Control de acceso y autenticación" y al reino de "Criptografía" vistos en la sección "2.1. Taxonomía de los patrones de Ataque" por las debilidades en los mecanismos de inicio de sesión y la falta de encriptación. Los ataques pertenecen a la categoría "Autenticación y Gestión de sesiones".

5.2 Pasos para explotación

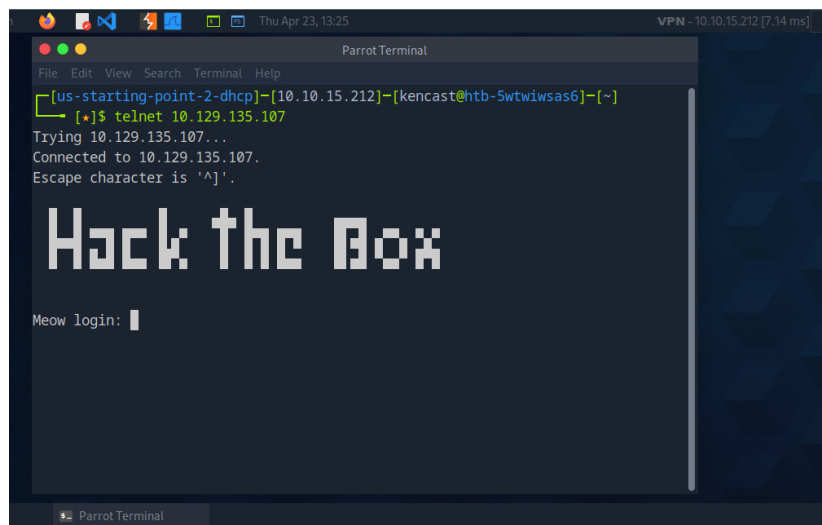


Figure 4: Conexión con Telnet

Como se menciona en la sección [4](#) el ataque consiste en lograr hacer login por medio de Telnet y obtener acceso al sistema. Para esto hacemos conexión a Telnet en el sistema objetivo por medio del comando `telnet {IP_OBJETIVO}` con `IP_OBJETIVO=10.129.135.107` como IP del sistema remoto al que se quiere conectar. En la figura [4](#) se observa que el comando muestra una pantalla de bienvenida y pide el nombre de usuario para hacer login.

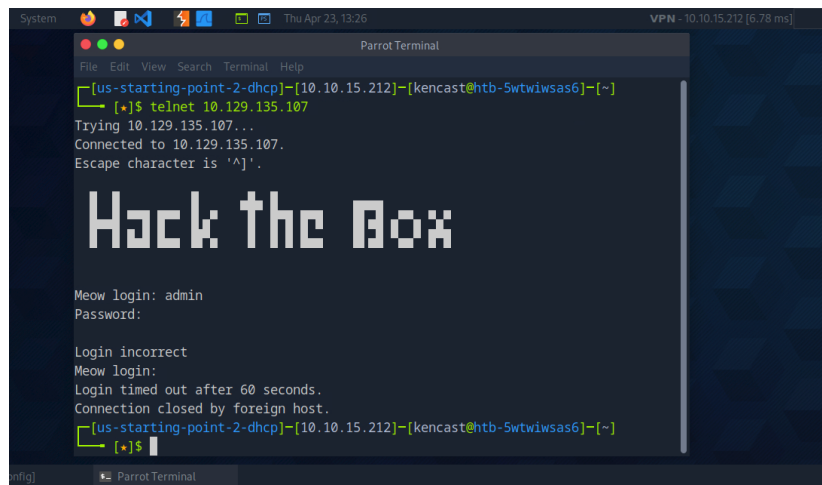


Figure 5: Intento fallido de login en Telnet

Por lo que sugiere el challenge, solo hay que encontrar el nombre de usuario correcto, la contraseña es vacía en este caso. Por lo que se intenta probar con algunos nombres de usuario comunes o que vienen por default en un sistema como `admin/root/administrator`. En la figura 5 se muestra un intento fallido con `meow login=admin`, por lo que este no es, y después de varios segundos el host cerró la conexión, con lo cual hay que abrirla con el mismo comando anterior.

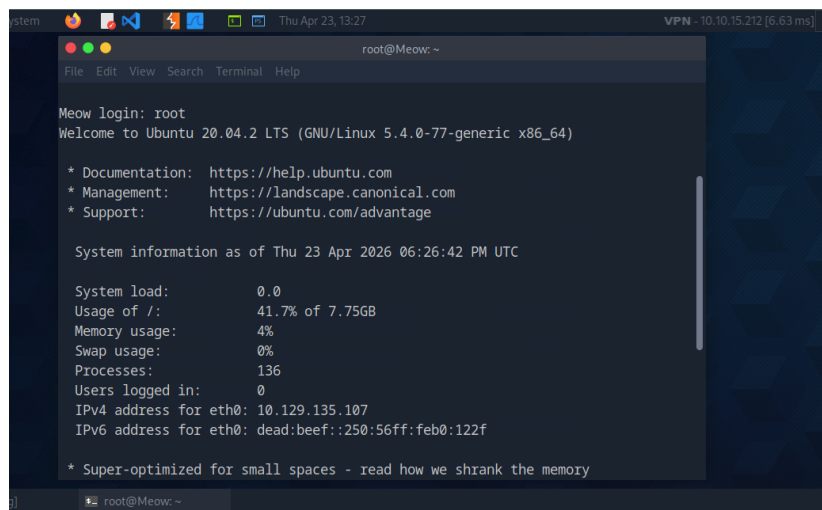


Figure 6: Acceso exitoso al sistema

Después se intenta con `meow login=root` y como se observa en 6 este nombre de usuario es el correcto y se logra acceder al sistema. En la terminal se muestra la versión del sistema operativo Linux, así como la distro Ubuntu 20.04.2 LTS, la fecha y la información relacionada con el hardware del sistema objetivo.

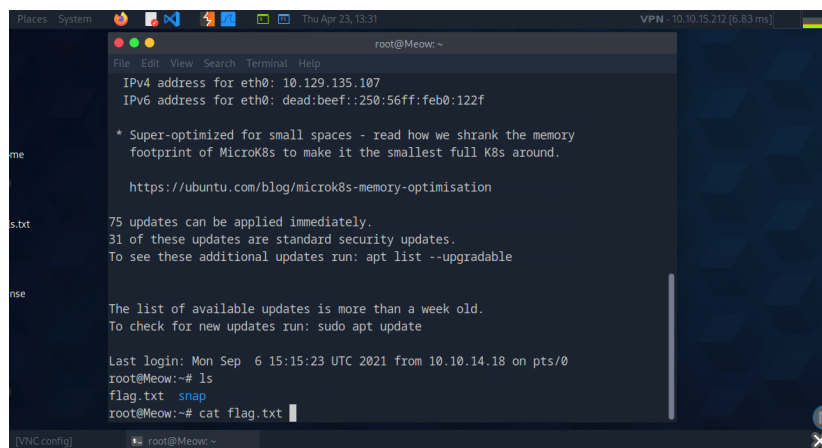
A screenshot of a terminal window titled 'root@Meow: ~'. The terminal shows the output of the 'ls' command, displaying files like 'flag.txt' and 'snap'. It also shows the output of 'cat flag.txt', which contains a message about system updates and a link to a blog post. The terminal window is part of a desktop environment with a top bar showing 'Places', 'System', and a clock. A status bar at the bottom indicates 'VPN - 10.10.15.212 [6.83 ms]'.

Figure 7: Vista de archivos y obtención de bandera

Finalmente, en la figura 7 se ve que la terminal está ubicada de manera remota en `root@Meow`, el sistema objetivo, por lo que podemos usar el comando de Linux `ls` para ver en qué directorio estamos ubicados y los archivos que hay en este. Lo que destaca es el archivo `flag.txt` que contiene un código que podemos ver por medio del comando `cat {NOMBRE_ARCHIVO}` para mostrar el contenido de `NOMBRE_ARCHIVO=flag.txt` en la terminal. Este código es necesario para ingresarlo en la plataforma HTB y completar el challenge correctamente.

6 Evidencia de resolución

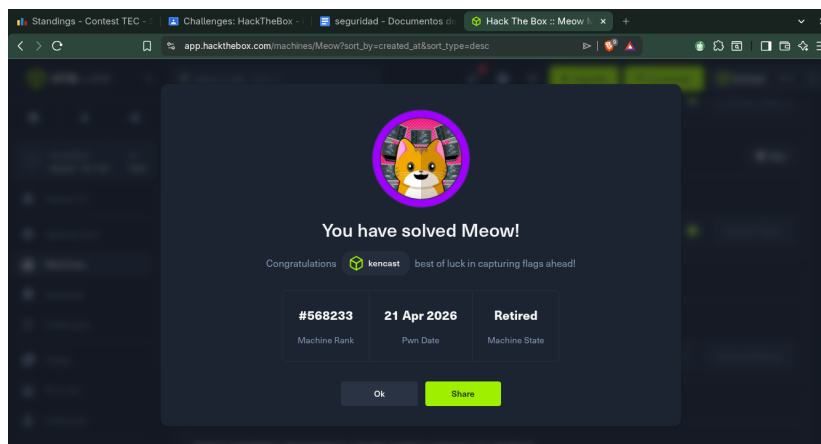


Figure 8: Challenge aceptado en HTB

En la figura 8 se muestra que el challenge Meow fue aceptado, la fecha no coincide con las otras capturas porque primero se completó el proceso y después se volvió a repetir todo para documentarlo.

7 Remediación

Para mitigar estas vulnerabilidades en un entorno de producción real, primero hay que optar por un protocolo más sofisticado que Telnet, por ejemplo SSH, para tener un acceso por terminal seguro con encriptación y fuertes mecanismos de autenticación. También es esencial analizar y proteger los sistemas con herramientas como Nmap para detectar puertos abiertos y otros posibles puntos de entrada para un atacante.

Desde las buenas prácticas de seguridad, es importante definir credenciales fuertes para las distintas aplicaciones con medidas como el cambio frecuente de estas para mantener su seguridad. Finalmente, es recomendado informarse de las debilidades de los servicios que se usan para evitar ser víctimas de ataques a estos. Las recomendaciones citadas anteriormente se relacionan fuertemente con los principios de seguridad desde el diseño (Security by Design) encontrados en 9:

- Requerir el uso de funciones, lenguajes y frameworks de seguridad verificada.
- Definir y usar estándares criptográficos para el manejo de datos y autenticación.

8 Lecciones aprendidas

Como este challenge era el primero que realizaba en HTB, al inicio estaba algo perdido de cómo funcionaba todo el ambiente de trabajo y de lo que había que hacer para obtener la bandera. Por lo que, investigando un poco, pude familiarizarme con la plataforma y entender la dinámica de los problemas. Las preguntas que salían en el challenge fueron muy útiles para guiarme sobre lo que debía investigar. Por medio de la consulta de distintos recursos conocí herramientas y servicios como Telnet, Nmap, OpenVPN, de los cuales no había escuchado. Así mismo, aprendí sobre las vulnerabilidades de Telnet y cómo es muy buscado por atacantes. Finalmente, hice uso de las plataformas CWE, CVE y CAPEC para encontrar vulnerabilidades, y entendí mejor cómo hacer un write-up y la importancia de estos para la recreación de ataques.

Lo que haría diferente sería ir documentando conforme voy haciendo el challenge para ahorrar más tiempo y también investigar los nombres que voy viendo para darme cuenta de posibles vulnerabilidades.

9 Recursos consultados

1. [Lab access HTB](#): información sobre OpenVPN y Pwnbox.
2. [Nmap](#)
3. [Telnet puerto 23](#)
4. [Casos CVE](#)
5. [CWE Common Weakness Enumeration](#)
6. [CAPEC Common Attack Pattern Enumeration and Classification](#)
7. [Prácticas de seguridad desde el diseño por Microsoft](#)
8. [Video de solución oficial como guía inicial](#)